

DevSecOps & Kubernetes Interview Questions – Explained

1. Docker Image Hardening

Reduce attack surface by using minimal base images (distroless/alpine), removing unnecessary packages, using multi-stage builds, running as non-root, and scanning images for vulnerabilities.

2. Docker Security & Integrity

Security is implemented using image scanning (Trivy) post-build, signing images using Cosign, and following SLSA framework for supply chain security and integrity verification.

3. Pod Security Context

Defines privilege and access control settings for Pods and containers, including user/group IDs, capabilities, read-only root filesystem, and SELinux/AppArmor profiles.

4. Pod Security Policies (Deprecated)

PSP was used to control security-sensitive aspects of pod specification but is deprecated in favor of Pod Security Admission.

5. Pod Security Standards & Admission

Defines Baseline, Restricted, and Privileged policies enforced using Pod Security Admission controller.

6. Pod Disruption Budget

Ensures minimum availability of pods during voluntary disruptions like node maintenance.

7. DevSecOps Pipeline for Java App

Pipeline includes code checkout, SAST, SCA, unit tests, build, containerization, image scan, signing, deployment, and runtime security monitoring.

8. Container Host Hardening & Sandboxing

Includes kernel hardening, removing unused packages, Seccomp (syscall filtering), SELinux/AppArmor (MAC), and sandboxing with gVisor or Kata Containers.

9. Kubernetes Secrets Management

External Secrets Operator integrates with secret managers, while Sealed Secrets encrypt secrets safe for Git storage.

10. Seccomp / AppArmor Implementation

Configured via Pod Security Context and enforced by container runtime and host OS.

11. Kubernetes Runtime Detection

Falco, Tetragon, and StackRox detect runtime threats using syscall and behavioral analysis.

12. IaC Scanning

Terraform and CloudFormation code is scanned using tools like Checkov, tfsec, and Terrascan.

13. Terraform Validate vs Plan

Validate checks syntax and configuration, Plan shows execution changes before apply.

14. SAST, SCA & SBOM

SAST scans source code, SCA checks dependencies, SBOM provides software component inventory.

15. CI Workflow – SAST for Java

Integrate tools like SonarQube or Semgrep in CI pipeline to scan Java code on every commit.

16. Sidecar Container

A helper container deployed alongside main container to handle logging, proxying, or security.

17. VM Patching Without Downtime

Use rolling updates, load balancers, failover, or blue-green strategy.

18. Patching Group of Servers

Use Ansible or Chef for automated and controlled patch rollout.

19. Canary Deployment

Gradual release to small user set for validation before full rollout.

20. Blue-Green Deployment

Two identical environments used to switch traffic instantly with rollback capability.

21. Secure Dockerfile

Use minimal base image, multi-stage builds, non-root user, and avoid hardcoded secrets.

22. Service Mesh – Istio

Provides traffic management, security, observability without application code changes.

23. mTLS in Istio

Encrypts service-to-service traffic using mutual TLS with automatic certificate rotation.

24. Istio Deployment Patterns

Sidecar injection adds proxies per pod, Ambient Mesh removes sidecars using node-level proxies.

25. OPA Gatekeeper

Policy enforcement engine to validate Kubernetes resources using Rego policies.

26. Docker Image Tag Management

Use semantic versioning, immutable tags, CI-driven increments, and Git-based release strategy.